

Course: GRC 102 - Information Security Governance

Assessment: Week 3 Lab Exercise - Security Governance: Roles, Responsibilities and Real-World Application

Student: Sisanda Lisa Masango

Registration Number: C11/26/CGRCE/17572

Date: 23 September 2026

EXECUTIVE CONSULTANT REPORT: INFORMATION SECURITY GOVERNANCE TRANSFORMATION

EXECUTIVE SUMMARY

TechGlobal's rapid expansion to 2,500 employees across five global offices has outpaced its information security governance framework. Operating under an informal, IT-centric model; where security decisions, risk acceptances, and operational execution are concentrated within the IT Director, creates severe organizational exposure. Strategic misalignment, unchecked single-point-of-failure risks, shadow IT, regulatory non-compliance, and complete Board-level opacity threaten TechGlobal's reputation and operational resilience.

This report establishes a scalable, business-aligned **Information Security Governance Operating Model**. Grounded in recognized industry frameworks (ISO/IEC 27014, COBIT 2019, NIST SP 800-53, and the Three Lines Model), this blueprint detaches security risk governance from IT operational delivery. It establishes clear cross-functional accountability, formalizes executive and Board oversight, implements a robust RACI matrix across 15 core governance activities, defines a major cyber-risk escalation workflow, and corrects foundational Segregation-of-Duties (SoD) conflicts.

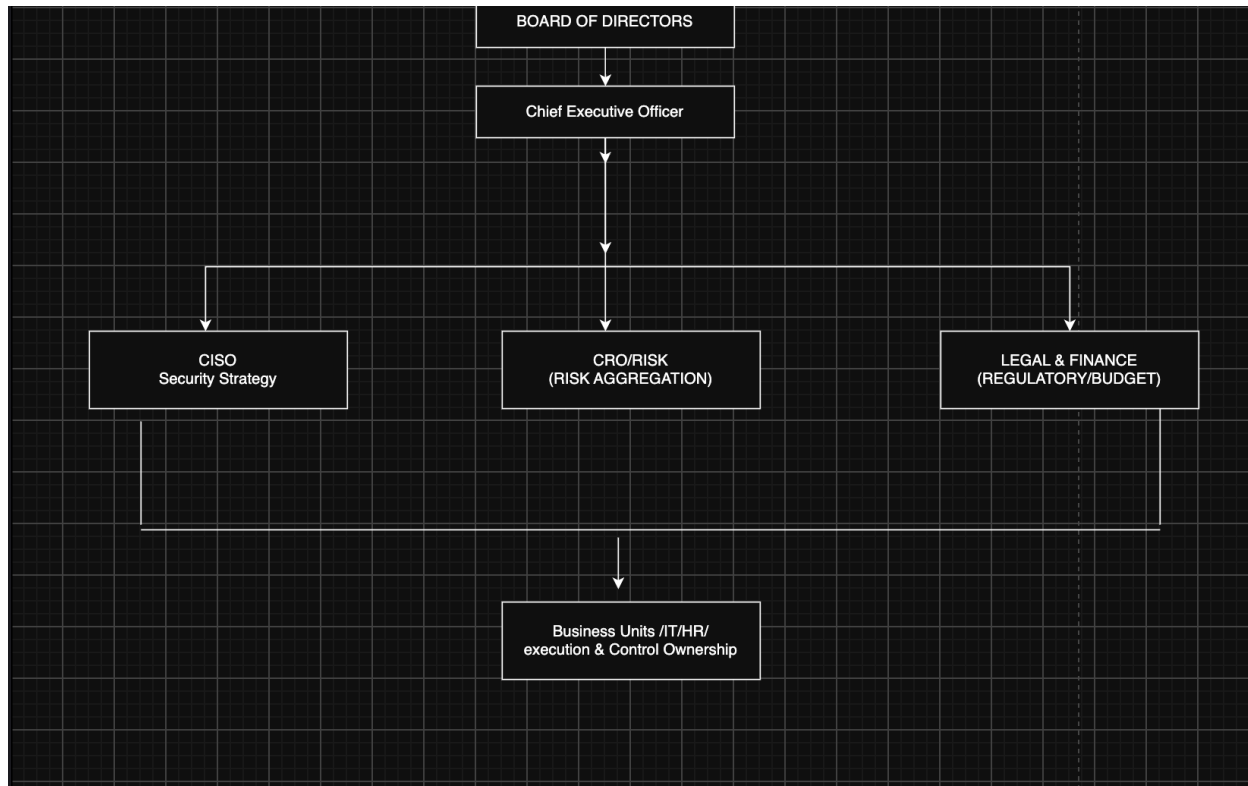
EVIDENCE BUNDLE 1: GOVERNANCE ARCHITECTURE & STAKEHOLDER MAP

1.1 Governance Gap Assessment

The existing informal, IT-centric governance model at TechGlobal exhibits five critical structural weaknesses:

Gap ID	Governance Weakness	Root Cause	Business & Risk Consequence
GAP-01	Concentration of Authority in IT Director	Lack of a dedicated CISO and independence between technology delivery and security oversight.	Conflict of Interest & Operational Bias: Security controls are frequently bypassed or deprioritized to meet IT deployment deadlines. The person building systems is approving their own risk trade-offs, leading to unmitigated system vulnerabilities.
GAP-02	Absence of Formal Governance Committees	Security decisions made in isolation without cross-functional input.	Siloed & Inconsistent Decision-Making: Business units independently implement disparate security practices and third-party tools, introducing unvetted shadow IT, incompatible controls, and fragmented risk exposure across regions.
GAP-03	Board & Executive Opacity	Lack of structured cyber-risk reporting and metrics upward to the CEO and Board.	Governance & Fiduciary Liability: Executive leadership cannot evaluate whether cyber risk aligns with organizational risk appetite. In the event of a breach, Board members face personal liability and legal non-compliance under regional data protection laws (e.g., GDPR, CCPA).
GAP-04	Unmapped Risk Acceptance & Escalation	No formalized risk appetite framework or escalation thresholds for material threats.	Unmanaged Exposure & Breach Volatility: High-impact operational cyber risks are accepted informally by low-to-mid-level IT staff without enterprise business impact analysis, exposing TechGlobal to catastrophic financial and operational disruption.
GAP-05	Misalignment Between Security and Business Strategy	Security is viewed strictly as an IT operational cost center rather than a business enabler.	Value Destruction & Growth Friction: Security policies fail to support business expansion across global offices, causing friction with product development teams, delays in customer acquisition, and non-compliance with regional regulatory standards.

1.2 Stakeholder Map



Stakeholder	Authority / Influence	Primary Interest	Information Needed	Governance Contribution
Board of Directors	High Authority / High Influence	Fiduciary duty, regulatory compliance, enterprise risk oversight, brand reputation.	Enterprise risk profile, top material cyber risks, audit findings, regulatory non-compliance issues.	Approves security governance charter, risk appetite, and strategic budget; provides independent oversight.
Chief Executive Officer (CEO)	High Authority / High Influence	Uninterrupted business growth, market expansion, operational resilience, strategic alignment.	Key Cyber Risk Indicators (KRIs), major incident reports, strategic alignment metrics, resource constraints.	Holds overall executive accountability; chairs Executive Security Council; allocates enterprise resources.
Chief Information Security Officer (CISO)	Medium-High Authority / High Influence	Information protection, security posture, incident response, vulnerability management, compliance.	Threat intelligence, vulnerability trends, control effectiveness, security architecture status, BU compliance rates.	Leads security strategy, formulates policies, monitors controls, and manages security operations and incidents.

Chief Risk Officer (CRO) / Risk	High Authority / Medium Influence	Enterprise Risk Management (ERM) integration, risk aggregation, risk treatment tracking.	Cyber risk registers, risk acceptance requests, loss exposure metrics, threat impact models.	Integrates cyber risk into ERM, establishes risk evaluation methodologies, and ensures independent risk validation.
Legal & Compliance	Medium Authority / High Influence	Regulatory compliance (GDPR, CCPA, ISO 27001), contractual liability, breach notifications.	Data privacy assessments, third-party exposure, regulatory change notifications, incident legal impact.	Advises on legal requirements, drafts breach notification protocols, and reviews vendor security contracts.
Finance / CFO	High Authority / Medium Influence	ROI on security investments, loss prevention, insurance coverage, cost-effective controls.	Security budget utilization, capital expenditure requests, cyber insurance terms, financial impact of risks.	Approves security capital allocation, manages cyber insurance policy, and audits financial control integrity.
Human Resources (HR)	Medium Authority / Medium Influence	Workforce risk management, joiner/mover/leave r (JML) processes, insider threat, culture.	Employee security training completion, policy violations, insider threat alerts, background check results.	Enforces HR security policies, integrates security into onboarding/offboarding, and manages disciplinary steps.
IT Director / Technology	Medium-High Authority / High Influence	Infrastructure availability, system performance, technical control execution, SLA delivery.	Technical security requirements, patch management schedules, system vulnerability reports.	Implements technical controls, remediates system vulnerabilities, maintains infrastructure, and drives business continuity.
Business Unit (BU) Leaders	Medium Authority / High Influence	Operational efficiency, revenue generation, customer satisfaction, product release velocity.	BU-specific risk posture, security policy impact on workflows, vendor security assessment outcomes.	Owns operational risk within business processes; enforces local policy compliance; implements business controls.

1.3 Proposed Security Governance Organisation Structure

The proposed governance architecture replaces single-point IT decision-making with a clear, hierarchical accountability model structured across six functional levels:

- **Level 1: Board Oversight (Board of Directors / Audit & Risk Committee)**
 - **Positioning:** Highest governing body responsible for enterprise risk oversight.
 - **Oversight Relationship:** Receives quarterly security posture updates, audit findings, and immediate notifications of Level 3 material cyber risks from executive leadership.
 - **Primary Authority:** Approves enterprise cyber risk appetite, governance charters, and major security capital investments.
- **Level 2: Executive Management (Chief Executive Officer)**
 - **Positioning:** Reports directly to the Board of Directors; maintains overall executive accountability for business performance, operational resilience, and strategic alignment.
 - **Oversight Relationship:** Direct administrative reporting line for both the CISO and CRO, ensuring governance and risk functions remain fully independent of IT operational delivery.
- **Level 3: Strategic Executive Governance (Executive Security Council)**
 - **Composition:** CEO (Chair), CISO, CRO, CFO, Legal Counsel, and IT Director.
 - **Function & Reporting:** Meets quarterly to align cybersecurity strategy with business growth, approve enterprise-wide security policies, allocate capital resources, and review high-severity corporate risks.
- **Level 4: Cross-Functional Operational Governance (Security Governance Committee)**
 - **Composition:** CISO (Chair), Enterprise Risk Lead, Legal Counsel, Head of HR, IT Operations Director, and Business Unit Leaders/Champions.
 - **Function & Reporting:** Meets monthly to manage the enterprise cyber risk register, evaluate control effectiveness, review operational standards, and resolve cross-departmental friction. Escalates unresolved strategic risks and material exceptions directly to the Executive Security Council.
- **Level 5: Dual Second-Line Governance Leadership**
 - Chief Information Security Officer (CISO): Reports administratively to the CEO. Directs Security Operations and GRC teams (covering threat management, vulnerability oversight, security architecture, and incident response).
 - Chief Risk Officer (CRO) / Enterprise Risk Function: Reports administratively to the CEO and functionally to the Board Audit & Risk Committee. Maintains independent risk validation, ERM framework integration, risk aggregation, and corporate risk register integrity.
- **Level 6: Operational Execution & Implementation Layer (First Line of Defense)**
 - **IT Operations (Infrastructure & Systems):** Reports through technology management; responsible for technical control deployment, system patching, network maintenance, infrastructure continuity, and baseline service level agreements.
 - **Business Units (Global Offices 1 to 5):** Led by BU Leaders and embedded BU Security Champions; responsible for local policy compliance, operational process risk ownership, and vendor onboarding compliance within daily business activities.

Key Reporting & Communication Pathways

1. **Upward Risk Escalation:** Operational security threats and vulnerabilities identified by IT or Business Units flow to the Security Governance Committee and CISO/CRO. Risks exceeding executive tolerance thresholds escalate to the Executive Security Council and Board Audit & Risk Committee.
2. **Downward Policy & Strategy Cascading:** Board-approved risk appetite standards and Executive Security Council strategic directives flow down through the CISO and Security Governance Committee for operational implementation across IT Operations and global Business Units.
3. **Independent Risk Assurance Loop:** The CRO maintains an independent reporting channel directly to the Board Audit & Risk Committee, ensuring cyber risk reporting is verified independently of technical management.

1.4 Consultant Justification Report

Context & Scope:

TechGlobal has reached an operational inflection point. With 2,500 employees distributed across five global offices, the organization can no longer rely on informal security decision-making concentrated within IT. Technology delivery and security governance serve two distinct corporate objectives: IT focuses on operational speed, availability, and capability expansion; security governance focuses on risk management, resilience, regulatory compliance, and asset protection. Consolidating both functions under the IT Director creates an inherent conflict of interest that compromises control effectiveness.

Structural Independence & Line Separation:

The proposed organizational architecture establishes a formal separation between technical execution (First Line of Defense) and security governance/risk oversight (Second Line of Defense).

1. **Establishment of the CISO Role:** The CISO is established as an executive role reporting administratively to the CEO (or dual-reporting to the CRO/Executive Committee) rather than the IT Director. This direct reporting line ensures security initiatives and risk escalations are evaluated based on enterprise business impact rather than IT operational constraints.
2. **Independent Oversight via CRO & Risk:** The CRO maintains independent oversight of enterprise risk methodologies, ensuring cyber risks are evaluated consistently alongside financial, operational, and strategic risks.
3. **Board Accountability:** The Board of Directors (via the Audit and Risk Committee) receives direct, unedited quarterly reports on cyber risk posture, material vulnerabilities, and strategic compliance metrics from the CISO and CRO.

Scalability for Multi-Region Tech Operations:

For an organization operating across five global offices, central strategy must pair with localized execution. This model incorporates **Business Unit Security Leads / Champions** embedded within each global office and business unit. These leads interface directly with the Security

Governance Committee, ensuring local regulatory mandates (e.g., GDPR in Europe, CCPA in the US) are reflected in operational workflows without creating fragmented security silos.

Decision Authority & Executive Escalation:

By structuring the **Executive Security Council** (chaired by the CEO) and the **Security Governance Committee** (chaired by the CISO), TechGlobal transitions from "informal IT approval" to institutional decision-making. Strategic security choices, capital allocations, and major risk acceptances are processed through multi-disciplinary review, ensuring complete visibility, legal compliance, and financial authorization.

EVIDENCE BUNDLE 2: ROLES AND RESPONSIBILITIES

2.1 Cross-Functional Governance Responsibility Matrix

Role	Purpose	Core Governance Responsibilities	Decision Authority	Reports/Escalate to	Key Performance Indicators(KPIs)
Board of Directors	Provide ultimate fiduciary oversight and approve cyber risk appetite.	Approve security governance charter, review material risks, ensure regulatory compliance alignment.	Enterprise risk appetite, major capital investments (\$500k+), board-level risk acceptance.	Stakeholders / Shareholders	Audit finding resolution rate Annual review of cyber risk appetite
CEO	Executive accountability for enterprise operations and strategic risk posture.	Align security strategy with business goals, sponsor security investments, lead crisis management.	Strategic security strategy, enterprise policy sign-off, major risk acceptance (100k - 500k).	Board of Directors	Security strategy execution milestone rate Executive incident response readiness
CISO	Security governance leadership, strategy, and operational security oversight.	Formulate security policy, design control framework, lead SecOps, oversee incident response.	Security architecture standards, tactical risk acceptance (<\$100k), security control selection.	CEO / Executive Security Council	Mean Time to Detect/Respond (MTTD/MTTR) Vulnerability remediation SLA compliance %
CRO/Risk	Enterprise risk integration,	Integrate cyber risk into ERM, validate risk ratings,	Cyber risk scoring methodology,	CEO / Board Audit & Risk Committee	% of cyber risks integrated into ERM

	independent assessment, and methodology definition.	maintain enterprise risk register.	risk aggregation rules, ERM framework standards.		Audit gap closure velocity
Legal & Compliance	Legal counsel, regulatory compliance oversight, and contract security review.	Interpret regulatory standards, review vendor contracts, manage data privacy compliance.	Legal liability threshold acceptance, regulatory disclosure actions, privacy policies.	CEO / Board of Directors	Regulatory compliance audit score (%) Contractual security review turn-around time
Finance / CFO	Financial governance, budgeting, loss exposure modeling, and cyber insurance.	Allocate security budgets, model financial impacts of risk, manage cyber insurance policy.	Security capital budget release, cyber insurance coverage parameters, financial loss limits.	CEO / Board of Directors	Security budget vs. actual variance (%) Cyber insurance adequacy ratio
Human Resources	Workforce governance, security culture, and insider risk enforcement.	Enforce JML security protocols, drive security awareness training, execute disciplinary policy.	Mandatory training enforcement, workforce disciplinary sanctions for policy breach.	CEO / Executive Security Council	Security awareness completion rate (>95%) Offboarding access revocation SLA compliance (<24 hrs)
IT Director	Technology infrastructure delivery, technical control execution, and system continuity.	Implement security controls, execute patch management, maintain disaster recovery readiness.	Technical infrastructure configuration, IT change management approval, system recovery tasks.	CEO / CISO (for security compliance)	Critical patch deployment SLA compliance (%) System availability & Recovery Time Objective (RTO) success rate

2.2 Role Profiles / Responsibility Cards

1. Board of Directors

- **Purpose:** Sets the organization's risk appetite and provides ultimate fiduciary oversight of information security governance.
- **Core Governance Responsibilities:** Reviews enterprise cyber-risk profile quarterly; approves cybersecurity risk appetite and governance frameworks; ensures legal/regulatory compliance.

- **Decision Authority:** Final approval on enterprise risk appetite, security governance charter, and material risk acceptances exceeding executive authority.
- **Reporting Obligations:** Receives quarterly security posture updates from CISO/CRO and immediate notifications during Level 3 material cyber incidents.
- **Performance Indicators:** Resolution rate of external audit recommendations; alignment of cyber risk posture with stated risk appetite.

2. Chief Executive Officer (CEO)

- **Purpose:** Holds ultimate executive accountability for operational resilience and aligning security posture with business growth.
- **Core Governance Responsibilities:** Chairs Executive Security Council; sponsors security budgets; enforces enterprise-wide compliance with security policies.
- **Decision Authority:** Authorizes enterprise security strategies, approves cross-functional security investments, accepts business risks up to enterprise threshold.
- **Reporting Obligations:** Reports regularly to the Board on security governance, regulatory alignment, and major incident outcomes.
- **Performance Indicators:** Implementation rate of strategic security milestones; enterprise-wide security training participation rate.

3. Chief Information Security Officer (CISO)

- **Purpose:** Leads security governance, strategy, policy creation, security architecture, and operational defense.
- **Core Governance Responsibilities:** Designs security policies; monitors control effectiveness; oversees incident response and vulnerability management; reports on KRIs.
- **Decision Authority:** Security architecture standards, security tooling selection, operational control implementation, temporary system isolation during incidents.
- **Reporting Obligations:** Reports administratively to CEO, functionally to Executive Security Council, and presents quarterly to Board Risk Committee.
- **Performance Indicators:** Mean Time to Detect (MTTD) and Respond (MTTR); percentage of critical vulnerabilities remediated within SLA window.

4. Chief Risk Officer (CRO) / Risk Function

- **Purpose:** Ensures independent oversight, risk aggregation, and integration of cyber risk into Enterprise Risk Management (ERM).
- **Core Governance Responsibilities:** Defines risk scoring methodologies; reviews risk registers; provides independent validation of security risk evaluations.
- **Decision Authority:** Risk evaluation methodology, ERM framework standards, validation or rejection of risk acceptance justifications.
- **Reporting Obligations:** Escalates aggregated enterprise risk exposures directly to CEO and Board Audit & Risk Committee.
- **Performance Indicators:** Percentage of mapped cyber risks incorporated into ERM; accuracy rate of risk impact projections.

5. Legal & Compliance

- **Purpose:** Ensures compliance with global data protection laws, manages contractual security risk, and oversees legal obligations during incidents.
- **Core Governance Responsibilities:** Interprets regulatory mandates (GDPR, CCPA, etc.); reviews vendor security terms; guides regulatory incident notifications.
- **Decision Authority:** Determination of legal reporting thresholds, approval of vendor privacy frameworks, regulatory disclosure authorization.
- **Reporting Obligations:** Reports regulatory compliance exposures and mandatory disclosure decisions to CEO and Board.
- **Performance Indicators:** Zero regulatory fines or non-compliance notices; percentage of high-risk third-party contracts reviewed within SLA.

6. Finance / CFO

- **Purpose:** Oversees financial risk exposure, allocates security capital, and manages cyber insurance coverage.
- **Core Governance Responsibilities:** Evaluates financial impact of cyber risks; funds security initiatives; maintains comprehensive cyber risk insurance.
- **Decision Authority:** Security budget allocation, release of emergency incident funding, cyber insurance policy terms.
- **Reporting Obligations:** Reports security expenditure ROI and insurance coverage adequacy to Executive Security Council.
- **Performance Indicators:** Variance between approved security budget and actual spend; cyber insurance claim recovery success rate.

7. Human Resources (HR)

- **Purpose:** Drives organizational security culture, manages joiner/mover/leaver (JML) security risks, and enforces disciplinary policies.
- **Core Governance Responsibilities:** Manages security awareness onboarding; executes offboarding access revocation tasks; manages insider threat procedures.
- **Decision Authority:** Mandating employee security training, applying disciplinary measures for security policy breaches.
- **Reporting Obligations:** Reports workforce compliance and policy violation metrics to Security Governance Committee.
- **Performance Indicators:** Employee security awareness completion rate (>95%); offboarding access revocation completed within 24 hours.

8. IT Director / Technology Function

- **Purpose:** Operates IT infrastructure, deploys technical security controls, and maintains technical service availability.
- **Core Governance Responsibilities:** Executes system patch management; implements technical security architecture; performs disaster recovery and backup tasks.
- **Decision Authority:** Infrastructure configurations, operational change management approval, routine patch scheduling.
- **Reporting Obligations:** Reports patch compliance, system availability, and technical control execution to CISO and Governance Committee.

- **Performance Indicators:** SLA compliance for critical security patch deployment; successful recovery time objectives (RTO) achieved during testing.

2.3 Conflict-Resolution Analysis

OVERLAPPING GOVERNANCE AUTHORITIES

1. IT Availability vs. CISO Security Controls (Patching vs. Operational Uptime)
2. BU Velocity vs. Security Risk Acceptance (Bypassing Controls for Speed)
3. CISO Risk Assessment vs. CRO ERM Rating (Disagreements on Risk Severity)

TO

GOVERNANCE RESOLUTION PRINCIPLES

1. Executive Escalation: Unresolved operational ties escalate to CEO/Council.
2. Business Impact First: Decisions evaluated against enterprise risk appetite.
3. Independent Validation: CRO provides binding risk impact scoring.

Overlap Area 1: IT Operational Availability vs. CISO Security Controls

- **Conflict Scenario:** The CISO mandates immediate deployment of an out-of-band emergency security patch to remediate a critical vulnerability. The IT Director resists, citing potential system downtime during peak business hours and missing service level agreements (SLAs).
- **Resolution Mechanism:** The issue is evaluated using the **Business Impact & SLA Framework**. If the vulnerability severity is CRITICAL (CVSS ≥ 9.0) with active exploitation, security policy mandates IT compliance within 24 hours. If IT requests a delay, the decision must escalate to the CISO and CRO. If unresolved, the CEO makes the final decision, and a formal Risk Acceptance Form is signed, documenting the business owner's assumption of financial exposure.

Overlap Area 2: Business Unit Growth Velocity vs. Security Control Compliance

- **Conflict Scenario:** A Business Unit Leader intends to onboard a critical third-party cloud software vendor to hit a quarterly revenue target, bypassing the mandatory CISO third-party security vendor risk assessment.
- **Resolution Mechanism:** The CISO holds veto authority over system connectivity and access grants for unvetted third parties. Local BU leaders cannot override security baseline reviews. If a BU leader insists on bypassing security controls, the risk must be formally submitted to the Security Governance Committee. Onboarding can proceed only if the CRO and CISO approve temporary compensating controls, or if the CEO accepts the residual exposure in writing.

Overlap Area 3: CISO Risk Rating vs. CRO Enterprise Risk Evaluation

- **Conflict Scenario:** The CISO categorizes a technical vulnerability as a High risk based on CVSS scoring, whereas the CRO views the operational risk as Low due to existing air-gapped network segmentations.
- **Resolution Mechanism:** TechGlobal applies a **Dual Risk Scoring Calibration Model**. Technical risk severity (owned by CISO) is combined with business context and

exposure impact (owned by CRO). In cases of disagreement, the CRO's enterprise risk impact framework governs the official classification on the Enterprise Risk Register, while the CISO retains authority to enforce technical perimeter defenses.

EVIDENCE BUNDLE 3: GOVERNANCE COMMITTEE ECOSYSTEM

3.1 Committee Structure & Interaction Model

The committee ecosystem operates through a three-tiered hierarchy that facilitates bi-directional communication, strategic oversight, and operational execution across all levels of the organization:

- **Executive Security Council (Strategic Oversight Tier)**
 - **Leadership & Cadence:** Chaired by the Chief Executive Officer (CEO); meets on a quarterly basis.
 - **Primary Focus:** Sets overall cybersecurity strategy, approves enterprise risk appetite, authorizes security capital investments, and provides top-level organizational direction.
 - **Bi-Directional Interaction:** Receives policy proposals, material risk escalations, and posture reports from the Security Governance Committee. In return, it issues executive guidance, risk tolerance boundaries, and strategic directives downward.
- **Security Governance Committee (Operational Governance Tier)**
 - **Leadership & Cadence:** Chaired by the Chief Information Security Officer (CISO); meets on a monthly basis.
 - **Primary Focus:** Oversees cross-functional policy adoption, monitors security control effectiveness, manages the enterprise cyber-risk register, and addresses cross-departmental risk trade-offs.
 - **Bi-Directional Interaction:** Serves as the central operational hub. It escalates high-impact risks and resource requests to the Executive Security Council while translating strategic priorities into actionable policies for execution teams.
- **Specialized Working Groups & Regional Networks (Execution Tier)**
 - **Cloud & Architecture Working Group:** Composed of technology and cloud operations specialists. It provides operational feedback and technical risk assessments upward to the Security Governance Committee while executing technical standards across global infrastructure.
 - **Incident Response Working Group:** Composed of SecOps, IT operations, and Legal representatives. It executes specialist directives from the Security Governance Committee, manages threat readiness, and escalates active major cyber incidents for executive oversight.
 - **Business Unit Security Champions Network:** Embedded across all five regional business units. It provides local governance oversight, channels regional risk insights upward, and drives policy compliance within local operational workflows without creating isolated security silos.

3.2 Terms of Reference (ToR) – Security Governance Committee

1. Purpose & Mandate

The Security Governance Committee (SGC) is established as TechGlobal's primary operational decision-making forum for cross-functional cybersecurity oversight. The SGC ensures security programs align with business goals, manages the enterprise cyber risk register, approves operational policies, and reviews security compliance across all five global offices.

2. Authority

The SGC operates under authority delegated by the Chief Executive Officer and Executive Security Council. The SGC is authorized to:

- Approve enterprise-wide information security policies and guidelines.
- Approve or reject risk treatment plans and temporary security exceptions under \$100,000 in risk value.
- Mandate corrective security actions across any business unit or operational department.
- Establish specialized working groups to address emerging security, regulatory, or technical threats.

3. Membership & Quorum

- **Chair:** Chief Information Security Officer (CISO)
- **Permanent Members:**
 - Representative, Enterprise Risk Management (CRO delegate)
 - IT Operations Director / Enterprise Architect
 - Legal Counsel / Data Protection Officer
 - Head of HR Operations
 - Head of Internal Audit (Observer)
 - Regional Business Unit Leaders (or designated BU Security Champions)
- **Quorum:** Mandatory attendance of Chair (or CISO delegate), plus at least four permanent members representing IT, Legal, Risk, and Business Units.

4. Meeting Cadence & Governance

- **Cadence:** Monthly (held on the second Tuesday of every month).
- **Escalation Path:** Decisions requiring enterprise risk appetite adjustments, emergency capital expenditures (\$100k+), or policy exemptions for executive leadership escalate directly to the Executive Security Council.

3.3 Sample Meeting Agenda

SECURITY GOVERNANCE COMMITTEE (SGC) - MONTHLY AGENDA Location: Virtual / Global Teams (HQ Room 401) Date/Time: October 13, 2026 | 14:00 - 16:00 WAT

14:00 - 14:10 | Welcome, Quorum Check & Review of Prior Action Items (CISO)

14:10 - 14:30 | Security Posture & KRI Dashboard Review (SecOps / CISO) • Patch compliance metrics, vulnerability trends, incident metrics.

14:30 - 14:50 | Enterprise Risk Register & Risk Exception Requests (Risk Lead) • Evaluation of 2 pending business unit risk acceptance requests.

14:50 - 15:15 | Cross-Functional Deep Dive: Third-Party Risk Management (Legal/GRC) • Vendor security review outcomes across global offices.

15:15 - 15:40 | Policy Review & Sign-off: Access Control Policy v3.1 (CISO/IT)

15:40 - 15:55 | Working Group Escalations (Cloud Security WG Lead)

15:55 - 16:00 | Summary of Approved Actions & Meeting Adjournment (Chair)

3.4 Sample Decision Log

Decision ID	Issue / Topic	Decision Owner	Decision Rendered	Rationale	Action Items & Assignee	Target Review Date
DEC-2026-01	BU-Europe requested exemption from mandatory Multi-Factor Authentication (MFA) on legacy ERP.	Security Governance Committee (Chair: CISO)	REJECTED. Temporary 30-day conditional waiver granted with mandatory IP-whitelisting.	Unconditional exemption poses an unacceptable breach risk. System must migrate to SAML/MFA within 30 days.	IT Ops to implement IP restriction within 48h. BU Lead to complete SSO integration.	10 Nov 2026
DEC-2026-02	Adoption of automated Cloud Security Posture Management (CSPM) tool for AWS/Azure environments.	CISO & Finance Representative	APPROVED. Capital spend of \$65,000 authorized.	Manual audit processes across 5 global offices are ineffective, creating cloud exposure.	CISO team to deploy tool; IT Ops to configure cloud API integrations by Nov 30.	15 Dec 2026
DEC-2026-03	Approval of updated Enterprise Password & Authentication Standard v2.0.	Security Governance Committee	APPROVED. Deprecates 90-day password rotation in favor of NIST	Modernises control baseline, lowers user fatigue, and improves	HR/IT to update employee handbook and configure	12 Jan 2027

			SP 800-63B guidelines.	security against credential stuffing.	IAM parameters by Nov 15.	
--	--	--	------------------------	---------------------------------------	---------------------------	--

3.5 12-Month Governance Calendar

Month	Recurring Governance Activities	Key Milestones & Deliverables
Q1: Jan	Monthly SGC Meeting; Annual Policy Review Cycle kickoff.	Release updated Information Security Policy suite.
Q1: Feb	Monthly SGC Meeting; Annual Policy Review Cycle kickoff.	Release updated Information Security Policy suite.
Q1: Mar	Monthly SGC Meeting; Third-Party Risk Management audit.	Vendor Risk Audit Report presented to SGC.
Q2: Apr	Monthly SGC Meeting; Annual Penetration Testing engagement.	External Penetration Test Report & Remediation Plan.
Q2: May	Monthly SGC Meeting; Disaster Recovery & BCP tabletop exercise.	Business Continuity Test Assessment & Lessons Learned.
Q2: Jun	Monthly SGC Meeting; Q2 Executive Security Council Meeting.	Board Risk Committee Q2 Report; Mid-year Budget Review.
Q3: Jul	Monthly SGC Meeting; Global Security Awareness Campaign kickoff.	Launch annual mandatory workforce security training.
Q3: Aug	Monthly SGC Meeting; Cloud Architecture & Identity Access audit.	Identity Governance & Privilege Access Audit Report.
Q3: Sep	Monthly SGC Meeting; Q3 Executive Security Council Meeting.	Board Risk Committee Q3 Report; Security Strategy Review.
Q4: Oct	Monthly SGC Meeting; Regulatory Compliance Audit (ISO 27001/GDPR).	Annual Compliance Gap Assessment & Remediation Tracker.
Q4: Nov	Monthly SGC Meeting; Cyber Insurance Coverage Renewal.	Finalized Cyber Insurance Policy & Budget Plan for next FY.
Q4: Dec	Monthly SGC Meeting; Q4 Executive Security Council Meeting.	Board Approval of Annual Security Strategy & Governance Report.

EVIDENCE BUNDLE 4: RACI ACCOUNTABILITY MATRIX

Security Governance Activity	Board	CEO	CISO	CRO	Legal	Finance	HR	IT/Tech Ops	BU Leader
1. Security Strategy Approval	A	C	R	C	I	C	I	C	C
2. Security Policy Approval	I	A	R	C	C	I	C	C	C
3. Enterprise Cyber-Risk Assessment	I	I	R	A	C	C	I	C	C
4. Risk Acceptance (Material >\$100k)	C	A	C	R	C	C	I	I	C
5. Security Budget Approval	C	A	R	I	I	C	I	I	I
6. Security Architecture Approval	I	I	A	I	I	I	I	R	C
7. Third-Party Security Review	I	I	A	C	C	I	I	C	R
8. Access Governance	I	I	A	C	I	I	C	R	C
9. Incident Response Governance	I	C	A	C	C	I	I	R	C
10. Material Incident Escalation	I	A	R	C	C	C	C	C	C
11. Regulatory Notification Decision	I	C	C	C	A	I	I	I	I
12. Security Awareness Programme	I	I	A	I	I	I	R	I	C
13. Vulnerability Remediation Oversight	I	I	A	C	I	I	I	R	C
14. Business Continuity / Recovery	I	C	C	A	C	C	C	R	R
15. Board Cyber-Risk Reporting	A	C	R	C	I	I	I	I	I

4.2 Analysis of Problematic RACI Assignments

1. Activity 3: Enterprise Cyber-Risk Assessment (CISO as Responsible, CRO as Accountable)

- **Analysis & Pitfall:** A common mistake in tech companies is assigning both "Accountable" and "Responsible" for risk assessments to the CISO. When the CISO evaluates their own controls, a self-audit conflict of interest occurs.
- **Correction Justification:** Assigning **CRO as Accountable** ensures independent oversight of the assessment methodology, while the **CISO as Responsible** executes the technical threat evaluation. This maintains separation between risk ownership and technical control implementation.

2. Activity 11: Regulatory Notification Decision (Legal as Accountable, CISO as Responsible)

- **Analysis & Pitfall:** Allowing IT or SecOps teams to decide whether to notify external data privacy regulators following an breach often leads to inappropriate exposure. Technical teams may underreport incidents due to technical ambiguity or fear of reprisal.
- **Correction Justification:** Legal is Accountable for deciding regulatory notifications. Legal counsel evaluates notification triggers against statutory deadlines (e.g., GDPR 72-hour window) and potential liability. The CISO acts as Responsible, feeding technical findings, breach scope, and forensics evidence to Legal.

3. Activity 13: Vulnerability Remediation Oversight (CISO as Accountable, IT as Responsible)

- **Analysis & Pitfall:** In TechGlobal's legacy model, IT was both Accountable and Responsible for vulnerability remediation. IT prioritized uptime and user feature deployments, leaving critical vulnerabilities unpatched for long periods.
- **Correction Justification:** The CISO is Accountable for setting patch standards, enforcing SLAs, and verifying remediation effectiveness. IT is Responsible for executing patch deployment and system restarts. This separation eliminates IT self-policing and enforces clear operational SLAs.

4.3 Implementation Guide for Management

How Management Uses the RACI Matrix

The RACI Matrix is an operational tool designed to eliminate ambiguity during strategy development, day-to-day operations, and security incident management.

- STEP 1: IDENTIFY GOVERNANCE ACTIVITY
- STEP 2: LOCATE SINGLE ACCOUNTABLE ROLE
- STEP 3: ENGAGE RESPONSIBLE EXECUTORS
- STEP 4: CONSULT & INFORM (C / I) STAKEHOLDERS

1. **Rule of Single Accountability ("Single A"):** Every activity has **exactly one** Accountable role. If two roles are listed as 'A', accountability becomes diluted, leading to delayed decisions and shifted blame during incidents.
 2. **Operational Planning & Approval Workflows:** Prior to kicking off projects, business leads consult the RACI matrix to identify who holds sign-off authority (Accountable) and who must execute technical reviews (Responsible).
 3. **Incident Escalation:** During a security incident, technical teams utilize the RACI matrix to route communications instantly. SecOps executes remediation (Responsible), the CISO directs response strategy (Accountable), Legal directs regulatory disclosures (Accountable for Notification), and the CEO is informed immediately.
-

EVIDENCE BUNDLE 5: CYBER-RISK ESCALATION & THRESHOLDS

5.1 Major Cyber-Risk Escalation Workflow

The major cyber-risk escalation workflow transitions risk management from ad-hoc IT handling into a standardized four-phase process. This ensures clear criteria, defined response times, and auditable governance actions across all levels of the enterprise:

- **Phase 1: Detection & Identification**
 - **Operational Trigger:** Operational SecOps, IT teams, or business unit staff detect a security vulnerability, system breach, unmitigated threat, or compliance exception.
 - **Initial Logging:** The issue is immediately logged into the enterprise Governance, Risk, and Compliance (GRC) ticket system with an initial technical severity assessment.
- **Phase 2: Evaluation & Classification**
 - **Joint Analysis:** The CISO and Enterprise Risk Lead review the event to evaluate technical severity, potential financial loss, system criticality, and legal/regulatory impact.
 - **Routing Determination:** Based on predefined criteria, the issue is routed into one of three structured escalation pathways.
- **Phase 3: Escalation Pathways & Decision Execution**
 - **Pathway 1 — Level 1: Operational Severity (Low Impact / Local Ops)**
 - **Scope:** Localized technical issues or low-CVSS vulnerabilities with isolated impact (< \$25,000 exposure).
 - **Authority & Action:** Managed directly by the CISO and IT Operations Lead. Remediation plans are logged and executed within standard 24-to-48-hour operational windows.
 - **Pathway 2 — Level 2: Executive Severity (High Impact / Cross-BU)**
 - **Scope:** Cross-business-unit risks, confidential data exposure, or system downtime affecting critical business operations (\$25,000 – \$100,000 exposure).

- **Authority & Action:** Escalated to the Executive Security Council. Emergency mitigation plans and temporary risk acceptances are reviewed and approved within 4 to 12 hours.
 - **Pathway 3 — Level 3: Material / Board Severity (Critical / Enterprise Exposure)**
 - **Scope:** Severe operational disruption (e.g., active ransomware), major data privacy breaches (>10,000 records), or material exposure (> \$100,000 exposure).
 - **Authority & Action:** Immediate escalation to the CEO, Board Audit & Risk Committee, and Legal Counsel within 1 hour. Triggers the Crisis Management Team, regulatory notification assessments, and public disclosure protocols.
- **Phase 4: Decision Recording & Closure**
 - **Auditable Logging:** All risk treatments, executive decisions, policy waivers, or remediation tasks are formally recorded in the Enterprise Risk Register.
 - **Post-Incident Assurance:** SecOps conducts a mandatory Root Cause Analysis (RCA) to refine controls, while Internal Audit receives regular updates to verify remediation closure.

5.2 Risk Escalation Threshold Table

Level	Example Trigger / Criteria	Decision Authority	Required Notification	Target Response Time
Level 1 – Operational	• Vulnerability CVSS < 7.0. • Minor localized incident without data loss. • Financial exposure < \$25,000. • System downtime < 2 hours (non-critical).	CISO / IT Operations Lead	Security Governance Committee (in monthly report).	Acknowledge: < 4 hours. Resolution: < 48 hours.
Level 2 – Executive	• Vulnerability CVSS 7.0 - 8.9. • Data breach affecting confidential BU data (<10,000 records). • Financial exposure \$25,000 - \$100,000.	CISO & CRO (Joint Approval)	CEO, Legal Counsel, Finance Lead, Affected BU Heads.	Acknowledge: < 1 hour. Resolution: < 12 hours.

	• System downtime > 4 hours on core service.			
Level 3 – Material / Board	• Critical zero-day vulnerability / active ransomware. • Major PII/GDPR breach (>10,000 records). • Financial exposure > \$100,000. • Widespread global downtime or severe regulatory exposure.	Board of Directors / CEO	Board Audit & Risk Committee, External Regulators, Law Enforcement, Insurer.	Immediate (< 15 mins). Crisis Mgmt Activated: Immediate.

5.3 Decision Recording & Assurance Not

To establish an auditable decision trail and satisfy governance standards, all decisions made during security escalations must adhere to the following protocol:

1. **Centralized Enterprise Governance Log:** Every risk acceptance, policy waiver, or major incident response decision is assigned a unique tracking ID (e.g., **RISK-ESC-2026-088**) and recorded in the GRC System.
2. **Mandatory Documentation Standards:** Entries must document:
 - Threat/Risk Description and CVSS/Financial Impact rating.
 - Business justification for risk acceptance or delayed remediation.
 - Compensating controls mandated by the CISO/CRO.
 - Expiration date for temporary risk waivers (maximum 90 days).
 - Formal digital signatures of designated Decision Owners.
3. **Independent Audit Review:** The Internal Audit function conducts quarterly sampling of closed risk tickets to verify that action items were completed within approved timelines and that escalation thresholds were followed correctly.

Segregation-of-Duties (SoD) Weakness Register

6.1 Segregation-of-Duties (SoD) Weakness Register

ID	Weakness / Conflict Description	Risk Created	Roles Involved	Recommended Corrective Control	Residual Risk / Review Cadence
SOD-01	IT Director Approves Own System Risk Acceptances. The IT Director currently evaluates IT risks and approves risk waivers for deployed systems.	Unmitigated security vulnerabilities introduced to meet deployment deadlines. Conflict between delivery speed and safety.	IT Director	Segregation of Risk Ownership: Risk acceptances must be validated by the CRO and approved by the CISO or CEO based on financial thresholds.	Low: Quarterly audit of risk acceptance logs by Internal Audit.
SOD-02	SecOps Engineers Write and Audit Security Controls. The security operational team deploys security tools and conducts self-audits on control effectiveness.	Self-policing leads to hidden control weaknesses and inaccurate posture reporting.	SecOps Lead / Security Engineers	Independent Control Validation: Internal Audit or an independent CRO delegate performs annual control testing.	Low: Annual third-party penetration testing and control audit.
SOD-03	IT Admins Hold Unrestricted Access and Manage Audit Logs. System administrators possess root access to production servers and write access to security event logs (SIEM).	Malicious activity or unauthorized system changes can be erased without detection.	IT System Administrators	Immutable Log Management : Centralize log ingestion into a write-once-read-many (WORM) SIEM managed exclusively by SecOps.	Low: Automated alert on SIEM log tampering or privilege abuse; semi-annual audit.
SOD-04	Software Developers Deploy Code Direct to Production. Developers	Unchecked or malicious code	Software Engineering Lead	CI/CD Pipeline Separation	Medium: Automated static/dynamic code analysis; monthly

	retain write and deployment privileges to production cloud environments.	deployed to production, breaching system integrity.		of Duties: Implement automated deployment pipelines requiring dual approval from QA and Security.	code release audit.
SOD-05	CISO Owns Procurement and Third-Party Security Approval. CISO selects security vendors and conducts vendor risk assessments.	Commercial bias, vendor lock-in, and unchecked third-party software risks.	CISO & Procurement Lead	Dual-Key Vendor Onboarding: Procurement owns contract execution, while Legal and CISO approve security and privacy terms.	Low: Annual vendor risk register review by Security Governance Committee.

Assurance & Decision-Tracking Summary Note

TechGlobal's governance transformation addresses foundational vulnerabilities by establishing clear boundaries between operational technology execution, risk evaluation, and executive oversight.

1. **Elimination of IT Self-Policing:** The separation of the CISO and CRO roles from IT operations ensures security controls and risk assessments are evaluated objectively, preventing IT operational speed from compromising security resilience.
2. **Enforceable Accountability:** Utilizing the 15-point RACI matrix and clear SoD rules eliminates ambiguity during routine maintenance and incident responses.
3. **Audit Readiness & Transparency:** By integrating formal committee structures, standardized decision logs, and explicit risk escalation thresholds, TechGlobal achieves full operational visibility. This protects executive leadership and the Board from fiduciary liability and provides a defensible security posture for global growth.

IMPLEMENTATION ROADMAP & TRANSFORMATION TIMELINE

MONTH 1: ARCHITECTURE & STRUCTURE

- Board formalization of Security Governance Charter.
- Formal appointment of CISO; reporting line re-assignment.
- Charter Executive Security Council and Security Governance Committee.

MONTH 2: RACI, SOD & POLICY DEPLOYMENT

- Operationalize RACI Matrix across all global offices.
- Implement SoD controls (SIEM log lock-down, CI/CD deployment rules).

- Roll out Risk Escalation Workflow and GRC decision logging tool.

MONTH 3: COMMITTEE OPERATIONALIZATION & TRAINING

- Hold inaugural Monthly Security Governance Committee meeting.
- Train global Business Unit Security Champions.
- Conduct first quarterly Executive Security Council briefing.

Recommendation & Next Steps

Management should immediately adopt this blueprint, submit the Security Governance Charter for Board signature, formalize the CISO appointment, and initiate Month 1 execution steps.

REFERENCES & CITATION CATALOG

- [1] International Cybersecurity and Digital Forensics Academy (ICDFA). (2026). *GRC102 Week 3 Practical Lab Brief: Roles, Responsibilities and Accountability in Security Governance (TechGlobal Governance Transformation Simulation)*. Course resource.
- [2] National Institute of Standards and Technology (NIST). (2024). *The NIST Cybersecurity Framework (CSF) 2.0*. NIST Cybersecurity White Paper 29.
- [3] NIST. (2024). *Cybersecurity Framework 2.0 FAQs and CSF 2.0 Guidance*. U.S. Department of Commerce.
- [4] International Organization for Standardization / International Electrotechnical Commission. (2020). *ISO/IEC 27014:2020 Information Technology — Security Techniques — Governance of Information Security*. ISO/IEC.
- [5] ISACA. (2019). *COBIT 2019 Framework: Governance and Management Objectives*. ISACA.
- [6] The Institute of Internal Auditors (IIA). (2020). *The IIA's Three Lines Model: An Update of the Three Lines of Defense*. The IIA.
- [7] U.S. Government Accountability Office (GAO). (2016; updated implementation information 2023). *Federal Chief Information Security Officers: Opportunities Exist to Improve Roles and Address Challenges to Authority*, GAO-16-686.
- [8] U.S. Securities and Exchange Commission (SEC). (2023). *Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure*, Release No. 33-11216.
- [9] SEC. (2023). *Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure – Small Entity Compliance Guide*.
- [10] ISC2. (2024). *ISC2 Cybersecurity Leadership Survey / Cybersecurity Leadership Program Announcement*. ISC2.
- [11] UnitedHealth Group. (2024). *Form 8-K: Material Cybersecurity Incident – February 21, 2024*. U.S. Securities and Exchange Commission.
- [12] UnitedHealth Group. (2024). *UnitedHealth Group Update on Change Healthcare Cyberattack*, March 7, 2024.
- [13] UnitedHealth Group. (2024). *Q2 2024 Cyberattack Update*.
- [14] U.S. Department of Health and Human Services, Office for Civil Rights. (2024). *Change Healthcare Cybersecurity Incident Frequently Asked Questions*.
- [15] European Parliament and Council of the European Union. (2016). *General Data Protection Regulation (GDPR) (EU) 2016/679*. Official Journal of the European Union.